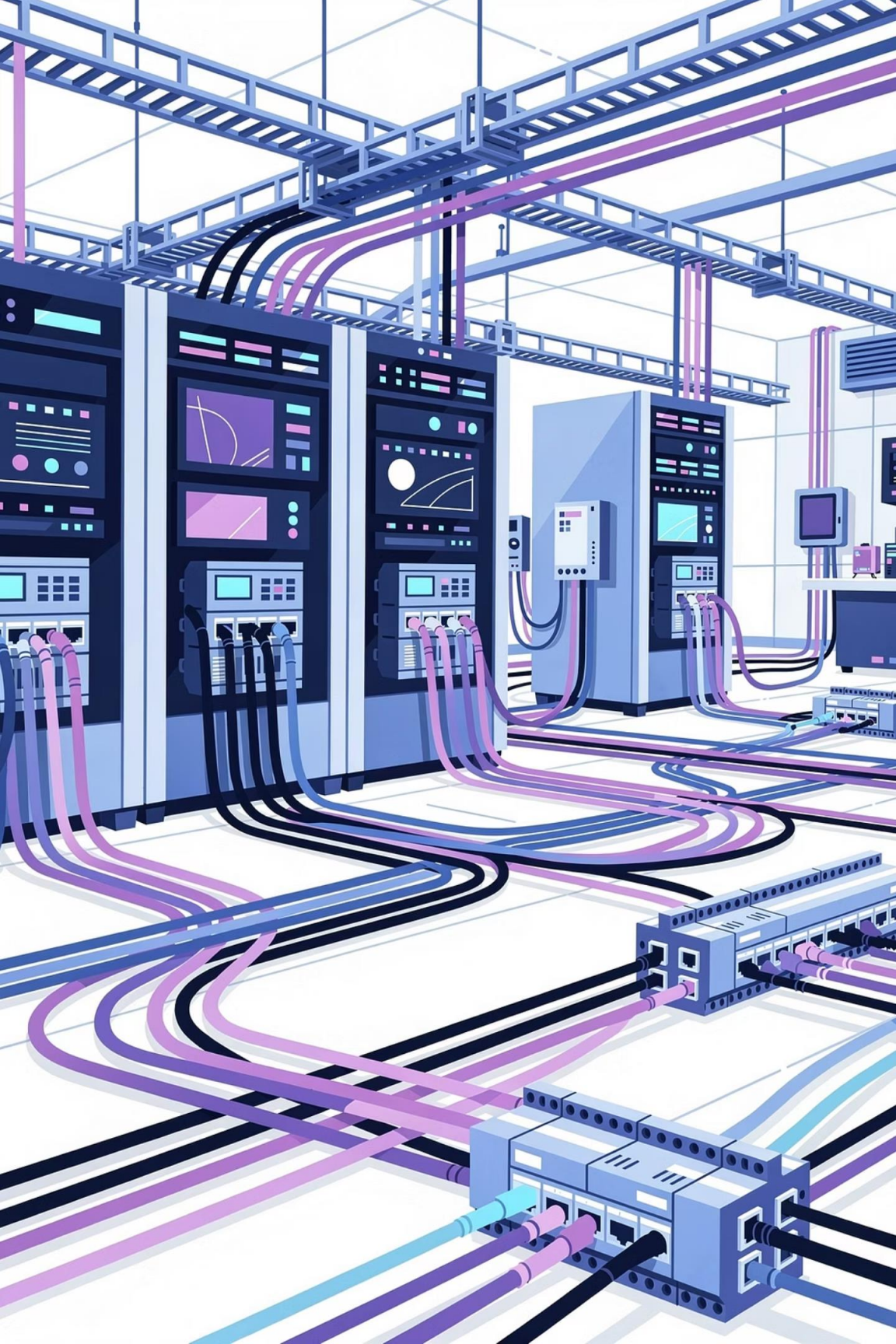




MODULE 04

Industrial Communication Protocols — A Security View

Course: Cybersecurity for Embedded & OT Systems

Focus: How OT systems communicate and what to observe safely

Recap — Module 03: Embedded Systems Fundamentals & Secure Boot

What We Learned in Module 03

Embedded systems form the computational core of industrial and OT environments

Microcontrollers (MCUs) integrate CPU, memory, and peripherals for real-time control

Industrial MCUs prioritize deterministic timing, reliability, and long lifecycles

RTOS enables structured task scheduling and deadline-based execution

Firmware defines device behavior and must be treated as a controlled asset

Security Foundations Introduced



Firmware lifecycle requires governance from development to updates



Secure boot ensures only trusted firmware runs at startup



Firmware integrity and digital signatures prevent unauthorized changes



Physical debug interfaces (UART, JTAG) must be restricted in production



Secure handling of development boards builds industrial security discipline

Bridge to Module 04

Secure embedded devices communicate continuously. Understanding how devices talk is the next step toward safe OT cybersecurity.

FOUNDATION

Why Communication Matters in OT

Communication protocols are the nervous system of operational technology environments. They serve as the fundamental pathways that enable industrial systems to function safely and efficiently. These protocols connect critical components including sensors that measure process variables, controllers like PLCs that execute control logic, and Human-Machine Interfaces along with SCADA systems that provide operators with visibility and control.

Any disruption or abnormal behavior in communication channels can have serious consequences. It can affect process stability, causing unpredictable operations. It may hide critical alarms from operators, preventing timely response to dangerous conditions. Most importantly, communication failures can create unsafe operating conditions that put personnel, equipment, and the environment at risk.

Understanding communication behavior is essential for safe monitoring and effective cybersecurity defense.

Sensors

Measure physical variables

Controllers

Execute control logic

HMI/SCADA

Operator interface



Role of Communication Protocols

What Protocols Enable

- Real-time data transfer from sensors to control systems
- Control commands sent to actuators and field devices
- Alarm and event reporting across the network
- Coordination between distributed devices

Design Characteristics

OT protocols are specifically engineered for industrial requirements:

Predictability

Consistent behavior patterns

Low Overhead

Minimal processing burden

Deterministic Timing

Guaranteed response times

This inherent predictability serves both operational efficiency and defensive monitoring strategies, making anomalies easier to detect.

Communication Patterns in OT

Industrial protocols generally follow three fundamental communication patterns. Each pattern moves data differently, exposes different metadata for observation, and requires a different monitoring focus for security purposes.



Polling-Based

Request–response model

Master device queries slaves cyclically

Example: Modbus RTU/TCP



Publish/Subscribe

Message broker architecture

Devices publish to topics, others subscribe

Example: MQTT, OPC UA Pub/Sub



Service-Oriented

Client-server interactions

Structured information models

Example: OPC UA Client/Server

-  Understanding these patterns is fundamental to recognizing normal behavior and identifying deviations that may indicate security concerns or operational issues.

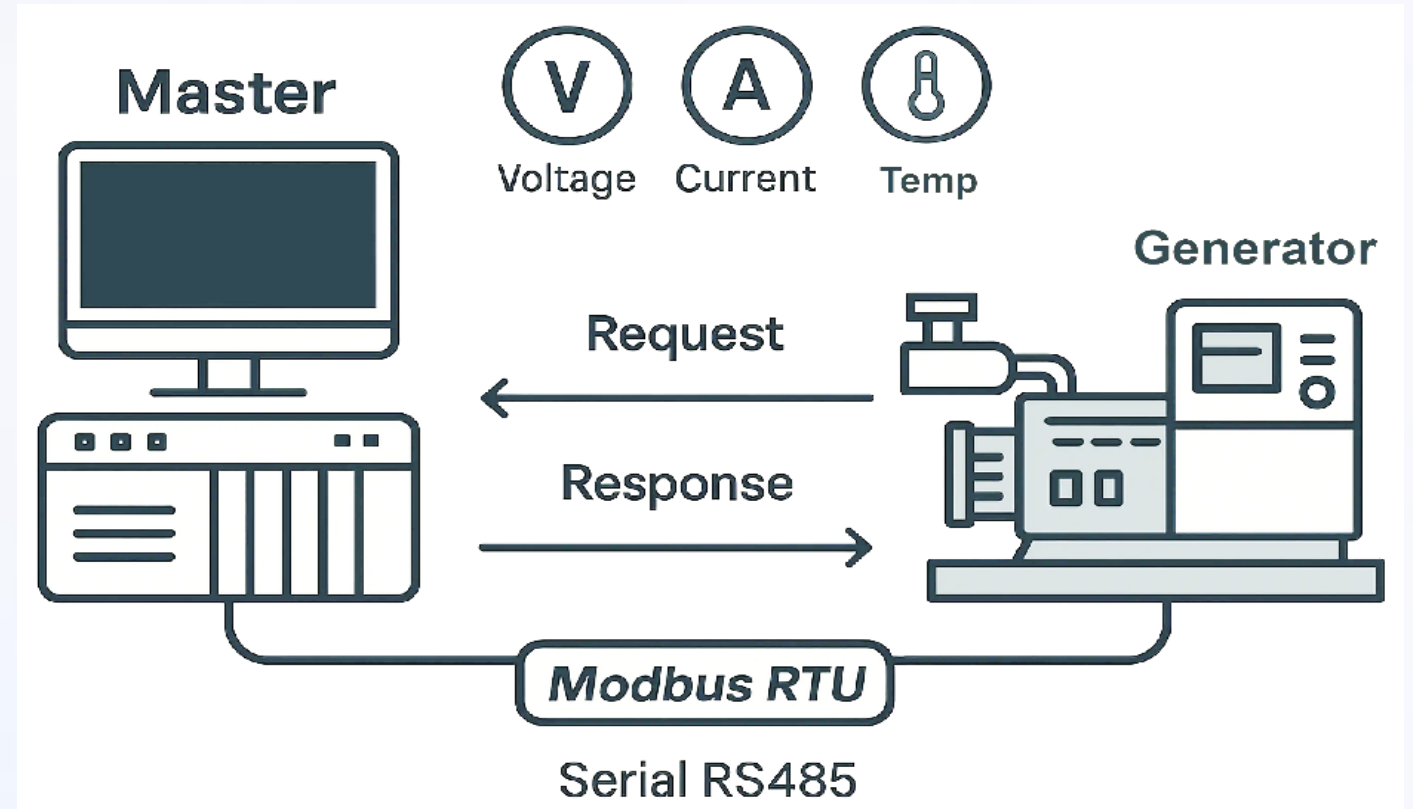
Polling-Based Communication (Modbus)

Modbus Protocol Overview

Modbus represents one of the most common polling-based protocols in industrial environments. In this architecture, one device designated as the master initiates all communication by requesting data from other devices called slaves. The slaves respond only when queried, creating a cyclic and highly repetitive communication pattern.

Common Usage Scenarios

- PLC communicating with remote sensors
- PLC reading from remote I/O modules
- SCADA polling multiple field controllers
- Gateway devices aggregating field data



Security Observation

Modbus traffic exhibits **very predictable timing patterns**. The cyclic nature of polling means that requests occur at regular intervals with consistent function codes. This predictability is advantageous for monitoring — any unusual commands, unexpected timing deviations, or communication from unknown addresses stand out clearly against the baseline behavior.

What to Observe in Modbus Traffic

From a defensive cybersecurity perspective, Modbus monitoring focuses on behavioral analysis rather than deep packet inspection. The goal is to establish normal communication baselines and detect deviations that may indicate misconfiguration, device failure, or security concerns.

	
New or Unknown Devices Watch for responses from slave addresses not in your asset inventory. Unexpected devices may indicate unauthorized access or shadow IT.	Unexpected Function Codes Monitor for function codes that deviate from established patterns. For example, write operations (FC 05, 06, 15, 16) appearing on read-only networks warrant investigation.
	
Polling Frequency Changes Sudden increases or decreases in polling rates can indicate network issues, device problems, or potential reconnaissance activity.	Write Operations Identify write commands in contexts where only read operations are expected. Unauthorized writes represent the highest risk in Modbus environments.

Monitoring focus: Behavior, timing, and access — not exploitation.



Publish/Subscribe Communication (MQTT)

MQTT Protocol Fundamentals

MQTT (Message Queuing Telemetry Transport) implements a publish/subscribe pattern fundamentally different from polling-based protocols. In this architecture, devices publish messages to named topics without knowing who will receive them. Other devices subscribe to topics of interest, and a central broker manages message delivery and routing.

This decoupled communication model enables flexible, scalable architectures particularly suited for telemetry collection and distributed systems.

Common Usage in OT

- **Telemetry Collection**

Remote sensors publishing measurement data at regular intervals

- **Analytics Platforms**

Edge devices streaming data to cloud or on-premise analytics engines

- **IoT-Enabled OT Systems**

Modern industrial IoT deployments leveraging MQTT for device integration

Defensive View of MQTT

While MQTT provides flexibility, it also introduces unique security considerations. Understanding the protocol's operational characteristics is essential for safe monitoring and risk management in OT environments.

Topic Structure

Document and monitor the complete topic hierarchy. Know what topics exist, who publishes to them, and who subscribes. Topic naming conventions should follow organizational standards.

- Wildcard subscriptions (+, #) require special attention
- Unauthorized topic creation may indicate compromise

Publishing Frequency

Establish baselines for message rates on each topic. Deviations from normal publishing patterns can signal device malfunction, network issues, or security events.

- Sudden increases may indicate data exfiltration
- Silence on critical topics requires investigation

Retained Messages

Monitor retained messages that persist on the broker. These messages are delivered to new subscribers and can contain outdated or malicious data if not properly managed.

Access Control

Track which clients have publish and subscribe permissions. Over-permissive access control represents a significant security risk in MQTT deployments.

- Regular access reviews are essential
- Principle of least privilege must apply

 **Security concern:** Topic misuse, over-publishing, or subscription to wildcard topics can signal misconfiguration, operational error, or potential security issues requiring investigation.

Service-Oriented Communication (OPC UA)



Protocol Characteristics

OPC UA (Open Platform Communications Unified Architecture) represents the modern evolution of industrial communication. It is a platform-independent, service-oriented protocol designed for secure, reliable data exchange in industrial automation.

Modern Industrial Protocol

Successor to classic OPC with platform independence and enhanced security features built into the specification

Structured Information Models

Rich, self-describing data models that provide context and relationships between data points, improving interoperability

Dual Communication Modes

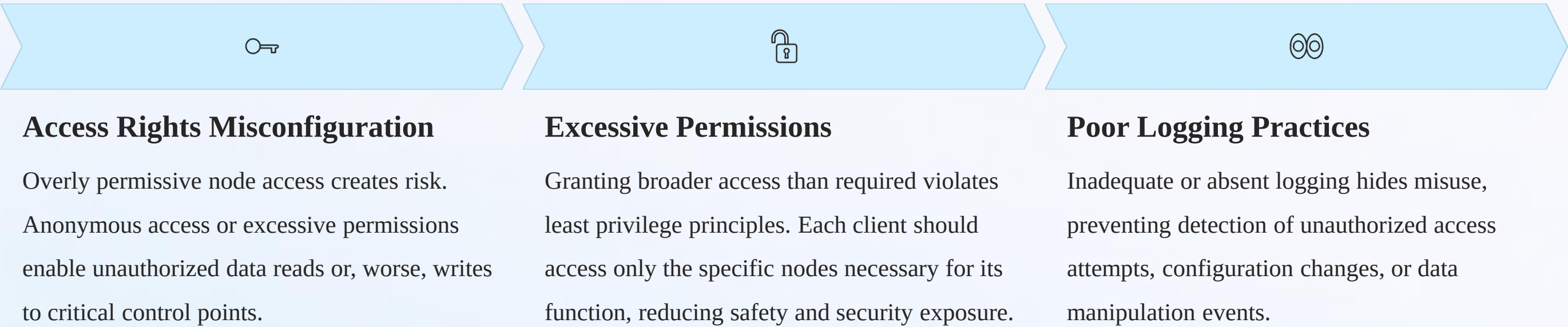
Supports both client-server request/response patterns and publish/subscribe messaging for flexibility

Common Applications

- SCADA systems integration
- Manufacturing execution systems (MES)
- Cross-vendor device integration
- Historian data collection
- Cloud connectivity for Industry 4.0

OPC UA: Security Awareness

Despite OPC UA's built-in security capabilities including encryption, authentication, and authorization, implementation challenges can create significant security risks in operational environments. The protocol's security is only as strong as its configuration.



Monitoring Focus

Who	How Often	From Where
Which clients or users are accessing the OPC UA server and specific nodes	Frequency patterns of access to detect anomalies or excessive polling	Source addresses and network segments to validate authorized access paths

Message Structure & Metadata

OT protocol messages contain two fundamental categories of information: the actual data payload and the metadata that provides context. Understanding both components is critical for effective monitoring and security analysis.

Data Payload

The core information being transmitted:

- **Values:** Sensor readings, process variables, status information
- **Commands:** Control instructions to actuators and devices
- **Configuration:** Parameter settings and control logic

Message Metadata

Contextual information about the communication:

- **Source Device**
Originating address or identifier
- **Destination Device**
Target address or node
- **Timestamp**
When the message was generated or transmitted
- **Function or Command Type**
Operation being performed
- **Status or Error Code**
Success/failure indicators and diagnostic information

Metadata is critical for safe monitoring and analysis. It provides visibility into communication patterns without requiring deep inspection of process data, supporting non-intrusive security monitoring in OT environments.

Why Metadata Matters for Security

Metadata provides the foundation for effective, non-intrusive security monitoring in OT environments. By analyzing communication context rather than payload content, security teams can gain visibility while minimizing operational impact.



Track Communication Paths

Metadata reveals the complete network topology and data flows between devices. Source and destination information maps legitimate communication patterns, making unauthorized connections immediately visible. This topology awareness is fundamental to network segmentation validation.



Detect Abnormal Behavior

Function codes, command types, and access patterns provide behavioral baselines. Deviations from established patterns — unusual commands, unexpected source addresses, or altered frequencies — signal potential security events without examining sensitive process data.



Correlate Events Across Systems

Timestamps and device identifiers enable correlation of events across multiple systems and log sources. When investigating incidents, metadata allows analysts to reconstruct sequences of actions and identify related anomalies across the entire OT environment.



Investigate Incidents

Metadata enables forensic analysis without deep packet inspection. During incident response, investigators can trace communication sequences, identify affected systems, and understand attack progression using metadata alone, preserving operational safety.



Key idea: Visibility without disrupting operations. Metadata-based monitoring achieves security observability while respecting the safety and availability requirements of production OT systems.

Timing, Heartbeats & Keep-Alives

OT systems depend heavily on precise timing mechanisms to maintain operational safety and detect failures. Understanding temporal characteristics is essential for both operational reliability and security monitoring.

Heartbeat Signals

Periodic messages that confirm a device is alive and functioning normally. Absence of expected heartbeats triggers immediate operator attention and may initiate fail-safe actions. Heartbeats provide continuous health monitoring without exchanging process data.

Cycle Time

The fixed communication interval at which polling occurs or data is exchanged. OT systems operate on deterministic cycles — typically milliseconds to seconds — ensuring predictable behavior. Changes to cycle time can indicate configuration errors or external interference.

Timeout Values

Maximum acceptable delay before declaring communication failure. Timeouts trigger fault conditions and may cause controllers to enter safe states. Proper timeout configuration balances responsiveness against false alarms from transient network issues.

Jitter Analysis

Variation in message timing relative to expected intervals. While some jitter is normal, excessive variation indicates network congestion, CPU overload, or interference. Monitoring jitter trends helps predict failures before they impact operations.

What Abnormal Timing Signals

- Device faults or hardware failures
- Network congestion or infrastructure issues
- Configuration problems or software errors

Security Implications

- Denial of service attacks affecting timing
- Reconnaissance causing timing changes
- Man-in-the-middle introducing latency

Logging & Event Visibility

Logs provide essential historical insight into system behavior, enabling both operational troubleshooting and security analysis. However, logging in OT environments requires careful implementation to avoid impacting system performance or stability.



Communication Logs

Records of protocol messages, connections, and data exchanges. Communication logs capture source, destination, timing, function codes, and success/failure status. These logs enable traffic pattern analysis and anomaly detection.



Access and Configuration Logs

User logins, permission changes, and system configuration modifications. Tracking who accessed what systems, when, and what changes were made is fundamental to accountability and incident investigation in OT environments.



Alarm and Event Logs

Process alarms, operator actions, and system events. These logs provide operational context for security analysis, helping distinguish between security incidents and normal process variations or operator interventions.



Error and Fault Logs

Device failures, communication errors, and diagnostic information. Error logs identify reliability issues that may create security vulnerabilities and help differentiate between malicious activity and system malfunctions.

Design Principles for OT Logging

Lightweight implementation: Logging must impose minimal CPU, memory, and network overhead on operational systems. Resource-constrained controllers and legacy devices have limited capacity for logging activities.

Passive collection: Log collection should occur passively whenever possible, using mirrored traffic or scheduled file retrieval rather than active queries that could disrupt operations or introduce latency.

Safe Monitoring Without Disruption

OT monitoring strategies must prioritize safety and operational continuity above all else. Unlike IT environments where brief disruptions may be acceptable, any interference with OT systems can cause process upsets, equipment damage, or safety hazards. Non-intrusive monitoring is not optional — it is mandatory.

Safe Monitoring Practices

Passive Packet Capture

Use network TAPs or SPAN ports to copy traffic without inline interference. Passive collection ensures monitoring cannot impact communication timing or introduce failure points into the production network.

Offline Log Analysis

Collect logs during maintenance windows or via scheduled transfers. Analyze logs on separate systems to avoid consuming controller resources during production operations.

Baseline Behavior Comparison

Establish normal operational baselines during stable periods. Compare current behavior against established baselines to identify deviations without active testing or queries.

Trend Analysis Over Time

Monitor long-term patterns rather than instantaneous states. Trending reveals gradual changes that may indicate emerging issues while avoiding real-time intervention in live systems.

Practices to Avoid

Active Scanning

Never perform active vulnerability scans or port scans against production OT devices. These activities can crash controllers, trigger safety systems, or corrupt running processes. Scanning must occur only in isolated test environments.

Stress Testing Live Controllers

Never load test or stress test operational control systems. Performance testing of PLCs, RTUs, and other controllers can cause failures with immediate safety and operational consequences.

Unplanned Configuration Changes

Never make configuration changes outside approved change management processes, even for security purposes. All changes require planning, testing, and operational approval.

❏ **Safety always comes first.** When security monitoring practices conflict with operational safety, safety takes precedence. Design monitoring strategies that achieve security visibility without introducing operational risk.

Protocol-Level Risk Awareness

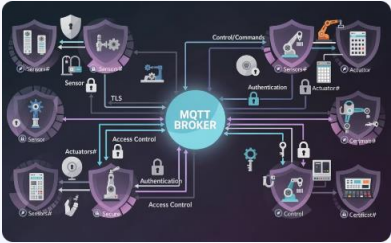
Each OT communication protocol presents unique security characteristics and risk profiles. Understanding protocol-specific vulnerabilities and limitations enables engineers to design appropriate layered defenses and monitoring strategies.



Modbus Risks

No built-in security: Modbus lacks authentication, encryption, or authorization mechanisms. Any device with network access can issue commands. Risks include unauthorized reads, malicious writes, and complete lack of accountability.

Mitigation: Network segmentation, firewall rules, and protocol gateways



MQTT Risks

Topic misuse and overload: Poorly configured topic permissions allow unauthorized publishing or subscribing. Excessive message rates can overwhelm brokers. Wildcard subscriptions may expose sensitive data.

Mitigation: Strong access control, topic hierarchy planning, rate limiting



OPC UA Risks

Access misconfiguration: Despite security capabilities, misconfigured access rights, disabled encryption, or poor certificate management creates vulnerabilities. Complexity increases configuration error risk.

Mitigation: Security audits, least privilege access, proper PKI implementation

Universal Protocol Challenges

All protocols share common risk factors including legacy device limitations and visibility gaps. Many OT devices were designed decades ago without security considerations. These legacy systems cannot be easily upgraded or replaced, requiring compensating controls at the network level. Additionally, complete visibility into all protocol traffic is challenging, especially in large, distributed OT environments.

Risk awareness helps engineers: Design layered defenses that address protocol-specific weaknesses, improve monitoring strategy with targeted observation, and reduce accidental disruptions through informed decision-making.

Module 04 Key Takeaways

OT communication protocols enable safe operations

Industrial protocols are the foundation of OT system functionality, enabling real-time control, monitoring, and coordination. Understanding these protocols is essential for maintaining operational safety and security.

Protocols are predictable by design

OT protocols emphasize deterministic behavior, consistent timing, and repeatable patterns. This inherent predictability makes anomaly detection more effective compared to IT environments with highly variable traffic.

Monitoring focuses on behavior and timing

Effective OT security monitoring observes communication patterns, timing characteristics, and behavioral baselines rather than searching for exploit signatures. Deviations from normal patterns reveal potential issues.

Metadata provides valuable security context

Protocol metadata — including source, destination, timing, and command information — enables security visibility without deep payload inspection, supporting non-intrusive monitoring in production environments.

Passive observation is preferred in OT

Safety-first monitoring requires passive techniques that cannot disrupt operations. Active scanning, stress testing, and intrusive queries are inappropriate for production OT systems.

Protocol awareness supports safety-first cybersecurity

Understanding protocol-specific characteristics, limitations, and risks enables informed security decisions that protect systems without compromising operational safety or availability.

MODULE 04 — Industrial Communication Protocols (Security View)

Reflection & Class Discussion

Why do OT communication protocols prioritize determinism and reliability over other factors?

Explain the key differences between polling, publish/subscribe, and service-oriented communication models in OT.

How does deep protocol visibility contribute to overall OT safety?

Discuss how timing and heartbeat messages are used to detect abnormalities in industrial networks.

Why is active scanning considered a significant risk in operational technology environments?

Homework & Assignments

1. List three primary roles that communication protocols play in OT systems.
2. Compare and contrast Modbus, MQTT, and OPC UA based on any three distinct characteristics (e.g., architecture, security features, data model).
3. Identify five specific metadata fields within an OT protocol's communication that are useful for security monitoring.
4. Draw a simple communication flow diagram for one of the following protocols: Modbus, MQTT, or OPC UA, illustrating a typical data exchange.
5. Explain, in detail, why passive monitoring is the preferred approach in critical OT environments and its advantages over active methods.

Applied Learning Task (Optional)



Monitoring Awareness Exercise

Choose one OT protocol (e.g., Modbus TCP, EtherNet/IP, DNP3) and describe the following:

- A typical, normal communication pattern for a specific operation.
- One timing or metadata indicator that you would monitor to detect anomalies.
- One specific abnormal behavior or deviation that, if detected, should immediately raise a security concern.

What's Next? (Module 05 Preview)

Asset Inventory & Risk Register for OT Systems

The next module focuses on establishing comprehensive visibility into your OT environment through systematic asset management and risk assessment. You cannot secure what you do not know — asset inventory is the foundation of effective cybersecurity.

		
Knowing What Assets Exist	Identifying Critical Systems	Recording Key Information
Building complete inventory of all OT devices, systems, and components	Determining which assets are most important to safety and operations	Documenting firmware versions, ownership, physical location, and configuration
		
Building an OT Risk Register	Linking Risk to Change Control	
Creating a simple, maintainable register of risks associated with each asset	Integrating risk management with operational change management processes	

You cannot secure what you do not know.

Thank you — let's move to Module 05